



# CRM Security & Data Protection

UK & USA Compliance Guide · March 2026

Let [sgo@xillio.io](mailto:sgo@xillio.io)

## 24/7

Autonomous AI operation

## AES-256

Encryption standard

## UK + USA

Compliance coverage



# Executive Summary

Xiilio.ai is an AI-driven lead generation and autonomous growth platform operating 24/7. As a platform that processes sensitive customer and prospect data, robust security and data protection are foundational to sustainable growth and client trust.



## End-to-End Encryption

All data protected in transit and at rest with AES-256 & TLS 1.3



## Zero-Trust Access

MFA, RBAC, and adaptive authentication across all accounts



## AI Threat Detection

Real-time anomaly monitoring and automated incident response



## Dual-Market Compliance

Full UK GDPR/DPA 2018 and US CCPA/state law compliance



## Independent Assurance

SOC 2 Type II, ISO 27001, Cyber Essentials, annual pen testing



## Privacy by Design

Security built into architecture — not bolted on afterwards

# Xiilio.ai & the CRM Ecosystem

## What Xiilio.ai Does

Xiilio.ai combines AI agents, performance marketing, and intelligent CRM connectivity to deliver a continuous pipeline of qualified leads — autonomously, around the clock.

### Data Processed Daily:

- Prospect & lead contact data
- Behavioural & engagement data
- CRM records (Salesforce, HubSpot, Pipedrive)
- Third-party enriched data
- Client business & sales strategy information



### 24/7 Autonomous

AI agents operate around the clock with no human intervention required



### CRM Integration

Seamless, scoped connection to leading CRM platforms with data minimisation controls



### Targeted Outreach

AI analyses thousands of prospects per minute, delivering precision-targeted campaigns

# Encryption & Access Control



## TLS 1.3

### Transport

All data in transit encrypted with TLS 1.3. Older protocol versions disabled.

## AES-256

### At Rest

All stored data encrypted to financial/government-grade AES-256 standard.

## E2E Pipelines

### AI Workflows

AI agent sequences operate within encrypted channels end-to-end.

## Key Rotation

### Management

Keys stored separately from data, rotated on defined schedules.

## Access Control Architecture

### Multi-Factor Auth

MFA required for all accounts. Hardware security keys for privileged users.

### Role-Based Access

Least-privilege RBAC enforced. Each role accesses only what the job requires.

### Adaptive Auth

AI assesses login risk by device, location, time & behaviour — adds steps when needed.

### Session Controls

Time-limited sessions, auto-expiry on inactivity, concurrent session prevention.

# AI-Powered Threat Detection & DLP



## Threat Detection Capabilities



### Real-Time Anomaly Detection

AI monitors user behaviour, API calls & access logs continuously. Suspicious activity triggers automated alerts.



### Fraud Prevention

Transaction patterns and login sequences are analysed to detect and block fraudulent activity instantly.



### Prompt Injection Protection

Specific controls prevent malicious inputs from hijacking AI agents to exfiltrate data.



### Supply-Chain Security

All third-party integrations are assessed; contractual data-handling requirements enforced on every partner.



### Automated Incident Response

Confirmed threats trigger automatic isolation, credential revocation & security team alerts within seconds.

## Data Loss Prevention

- Admins define sensitivity classification rules to prevent unauthorised data export
- AI monitors all data movement in real time
- Export and download activity logged with full audit trails
- AI agents access only the CRM fields required for each specific task
- Suppression lists enforced automatically across all outreach campaigns

# United Kingdom: UK GDPR & DPA 2018

*Regulated by the Information Commissioner's Office (ICO)*

## Lawful Basis

Legitimate interest for B2B prospecting; consent available where required. Documented per activity.

## Purpose Limitation

Data not repurposed without appropriate disclosure and, where necessary, fresh consent.

## Data Subject Rights

Access, rectification, erasure, portability & objection — exercisable via self-service portal.

## International Transfers

UK IDTAs or adequacy decisions govern all transfers of UK personal data outside the UK.

## Data Minimisation

AI agents collect only the personal data necessary for the specific task at hand.

## Storage Limitation

Automated retention policies ensure data is held only as long as operationally necessary.

## DPIA Requirement

Data Protection Impact Assessments conducted for all high-risk AI processing activities.

## ICO Registration

Xiilio.ai maintains appropriate ICO registration as controller and/or processor.

# United States: CCPA & State Privacy Laws

*A patchwork of state laws plus sector-specific federal regulations*

## CCPA / CPRA Rights

Consumers may know, opt-out & delete. Xillio.ai never sells personal data without disclosure.

## Privacy Notices

Clear, plain-language notices explain all data collection and AI-driven processing practices.

## CAN-SPAM / TCPA

All AI outreach configured with required opt-out links; suppression lists enforced automatically.

## FTC AI Guidance

Fairness, transparency and explainability principles applied to all AI lead scoring models.

## Opt-Out Mechanisms

Where AI processes customer PII, opt-out rights are clearly disclosed and technically enforced.

## Expanding State Laws

Ongoing monitoring of VA, CO, CT, TX and other state privacy laws as they come into force.

## Sector-Specific Rules

Additional HIPAA or GLBA controls available for healthcare and financial services clients.

## Federal Privacy Watch

Xillio.ai monitors emerging federal privacy legislation to adapt proactively ahead of enactment.

# UK vs USA: Side-by-Side Comparison

| Requirement         | UK (UK GDPR / DPA 2018)                            | USA (CCPA / State Laws)                         |
|---------------------|----------------------------------------------------|-------------------------------------------------|
| Lawful Basis        | Legitimate interest, consent, or contract          | Business purpose; sector consent where required |
| Individual Rights   | Access, rectify, erase, port, object               | Right to know, delete, opt out of sale          |
| Data Transfers      | UK IDTA or adequacy decision required              | SCCs for EU; state laws evolving                |
| Breach Notification | ICO within 72 hrs; individuals without undue delay | State AG: 30-90 days; sector rules apply        |
| AI Processing       | DPIA required; AI Act alignment considered         | FTC guidance on fairness; sector rules emerging |
| Data Retention      | Defined schedule; automated deletion enforced      | Purpose-limited; deletion within 45-90 days     |



# Data Governance & Privacy by Design



## Privacy by Design

- Privacy impact review before every deployment
- Data minimisation enforced at architecture level
- Most privacy-protective defaults configured by default



## Consent & Transparency

- Consent withdrawal technically enforced
- AI explainability traces every prediction
- Plain-language processing notices for all individuals



## Audit Trails

- Tamper-evident logs of all data access & changes
- Retained per UK and USA regulatory minimums
- Exportable for compliance investigations



## Vendor Management

- Pre-engagement security assessments mandatory
- Data processing agreements per GDPR Art. 28
- Regular compliance review of all sub-processors

# Incident Response & Business Continuity

## 01 Detect

AI monitoring flags anomaly instantly. Incident classified by severity.

## 02 Contain

Automated isolation of affected systems. Compromised credentials revoked.

## 03 Notify

Clients, regulators (ICO / State AGs) and individuals notified within required timelines.

## 04 Recover

Tested BCP & DR plans invoked. RTO / RPO targets met. Full post-incident review.

## Regulatory Notification Timelines

### UK ICO

**72 hours**

After becoming aware of breach

### UK Individuals

**No undue delay**

If high risk to rights & freedoms

### US State AGs

**30–90 days**

Varies by state and sector

### Clients

**Immediately**

Ahead of or alongside regulatory notice

# Security Certifications & Independent Assurance



## SOC 2 Type II

Annual independent assessment of security, availability, integrity, confidentiality & privacy controls.



## ISO 27001

Systematic, risk-based approach to protecting all information assets via certified ISMS.



## Penetration Testing

Regular third-party pen tests simulate real-world attack scenarios to identify and remediate vulnerabilities.



## GDPR Readiness

Annual UK GDPR compliance assessment covering DPIAs, data flows, and sub-processor agreements.



## Cyber Essentials (UK)

UK Government certification confirming fundamental cyber hygiene controls are in place and verified.

# Shared Responsibility Model

## Xiilio.ai Secures

- Platform infrastructure & AI agent pipelines
- End-to-end encryption in transit and at rest
- Zero-trust authentication architecture
- Real-time AI threat monitoring & DLP
- Regulatory compliance framework
- Security certifications & audits
- Incident detection & response

## Client Configures

- Maintain accurate user account records
- Enforce MFA for all staff accounts
- Review RBAC configurations regularly
- Keep privacy notices up to date
- Conduct DPIAs for high-risk activities
- Maintain Article 30 processing register
- Train staff on social engineering threats



# Security. Compliance. Trust.

Xiilio.ai's security framework is built for the most rigorous data protection environments in the world — the United Kingdom and the United States. Because the next top performer isn't just capable. It's trustworthy.



Get in touch:

**letsgo@xiilio.io**